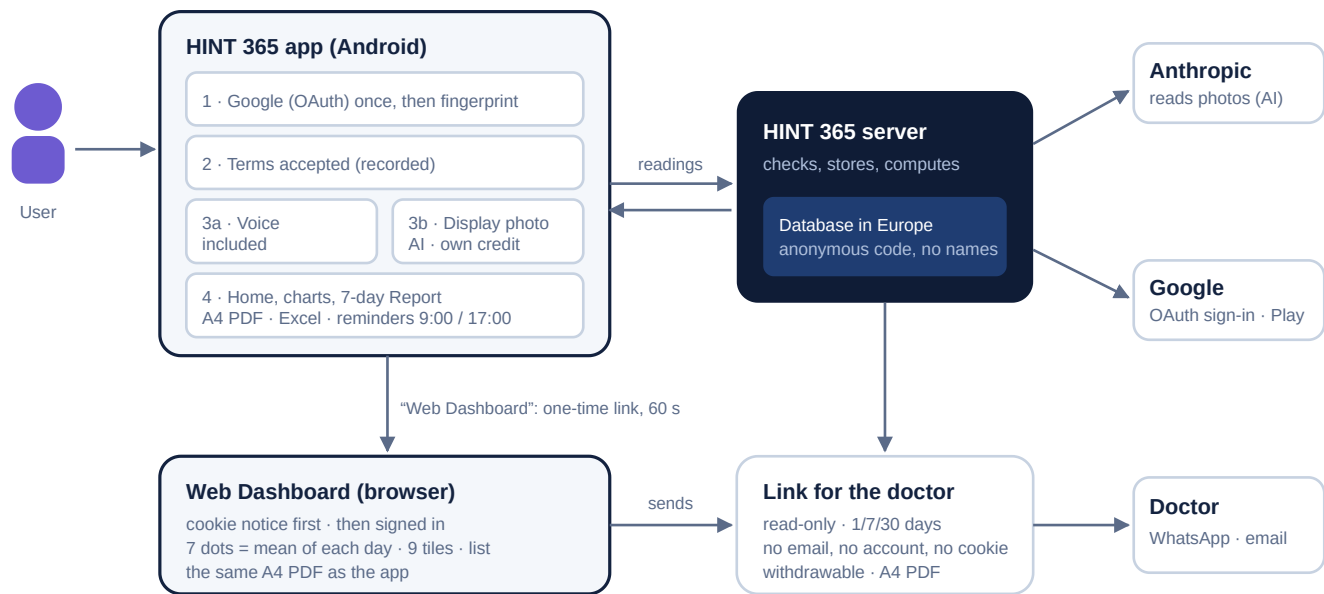


Functional overview

What the app does, who does what and in which order. A blood-pressure diary for Android, with a web dashboard and reports for the doctor.

The flow from the phone to the doctor



The user's path

1. **Installs** the app from the public link `/download` (later from Google Play).
2. **Signs in with Google** once, through OAuth 2.0 / OpenID Connect (a signed ID token, never the password), and gives privacy consent.
3. **Accepts the terms of use**, binding, at the first installation and after every update: without acceptance the app does not open. Every acceptance is recorded (anonymous code, phone, versions, text fingerprint, date).
4. **Every day** unlocks with the phone's fingerprint or PIN, and stays signed in until "Sign out".
5. **Records** a reading: by voice (**SYS**, **DIA**, **PUL**, checked and confirmed on screen) or by photographing the display (AI features).
6. **Looks back**: last reading, the week, the Report with charts and tiles.
7. **Shares**: PDF or Excel from the phone, or Web Dashboard → "Send to the doctor".
8. **Changes phone**: signs in with Google and finds everything. **Signs out** or **deletes the account** at any time.

Costs and who is paid

What	Cost	Paid to
HINT 365: app, charts, reports, Web Dashboard, keeping the readings	5 \$ a year, cancel any time	The app's owner, through Google Play
AI features, optional: Scan of the monitor (available now); anonymous medical documents (coming)	Pay-per-use, ≈ 0.006 \$ a photo	Anthropic, from the user's own credit

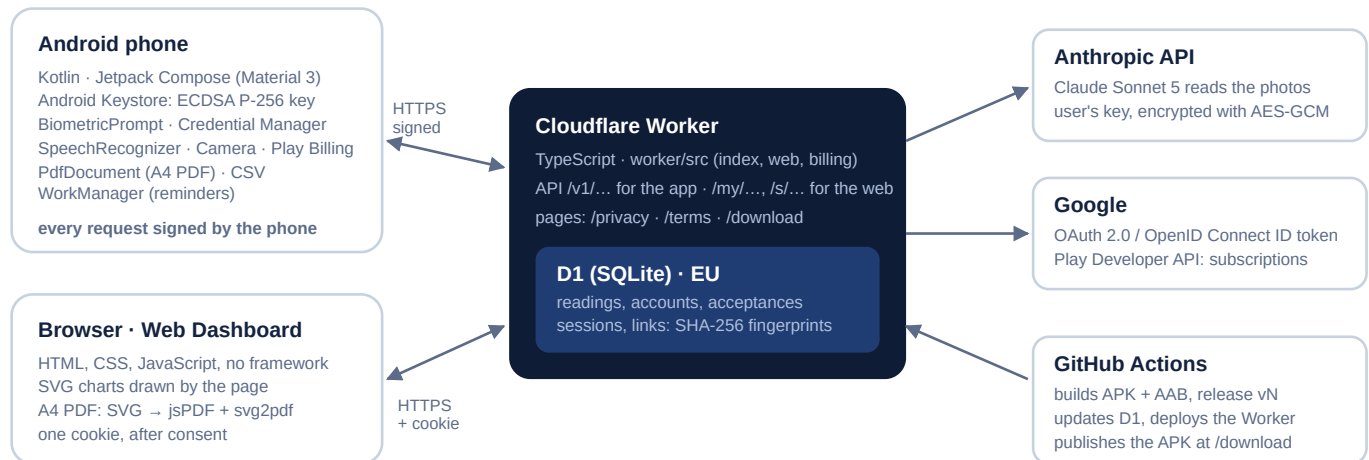
One app; the AI features are on or off (never "Premium"). The Anthropic credit is the user's own.

Fixed rules

- No diagnosis, no advice, no judgement of the values: no coloured zones, no "normal".
- Labels always **SYS**, **DIA**, **PUL**. Pressure and pulse never in the same chart.
- Charts: 7 days, one dot per day = the mean of that day's readings (explained before the charts), value next to it, axis with day numbers only.
- The same A4 PDF from the app and from the web; the web downloads it at once as a file.
- No red anywhere: **SYS** violet, **DIA** teal, **PUL** amber. No colour means "good" or "bad".
- Scan is on only when Anthropic has just said yes (valid key, credit): a minimal request on opening if the last check is over an hour old, after every error and when the screen is pulled down.
- Readings kept at most 365 days, deleted nightly; only the acceptances of the terms remain, as proof.

Architecture and technology

The components, how they talk, where the data live and how a new version is released.



Components

Part	Technology	Folder
Android app	Kotlin, Compose, minSdk 26, target 34	android/
Server	Cloudflare Workers, TypeScript	worker/src/
Database	Cloudflare D1 (SQLite), EU jurisdiction	worker/schema.sql
Web dashboard	HTML/JS, own SVG charts, jsPDF + svg2pdf	worker/public/my/
Photo reading	Anthropic Messages API	index.ts
Sign-in	Sign in with Google (OAuth 2.0 / OpenID Connect) + phone key	Google.kt
Subscription	Google Play Billing + Play Developer API	Billing.kt , billing.ts
Build, release	GitHub Actions, Gradle, Wrangler	.github/workflows/
Guides, documents	HTML → PDF (Playwright)	docs/

Database tables

persons · accounts (anonymous code, encrypted fingerprint of the Google account, no email; subscription sub_token , sub_until , sub_state) · measurements readings · scans photo readings · ledger credit and costs · person_keys encrypted Anthropic keys · acceptances accepted terms (append-only) · web_codes , web_sessions , web_shares web access and doctor links · settings , invites .

Extending

Modular: lab reports will be a new module in web.ts and app.js .

Security and data

- Phone:** a private key that never leaves the phone signs every request; the server refuses bad signatures or clocks off by more than 5 minutes.
- Web:** a 60 s one-time code in the # part of the address becomes the only cookie, hint_s (technical, 7 days, HttpOnly, Secure, SameSite=Strict), set only after the cookie notice is accepted; the choice stays in local storage. The app uses no cookies.
- Doctor links:** read-only, fixed period, expire in 1–30 days, withdrawable; no email, no account, no cookie.
- Remote switch-off:** the app version travels with every request; settings holds app_min_version , app_blocked , app_off . Owner only, from the web Admin area.
- Owner's area** (web, owner only): usage numbers per anonymous code (joined, last opened, readings, AI on), D1 size against the 500 MB free limit. Never readings, reports or names.
- Subscription** (ready, off until Google Play): Play Billing, checked with the Play Developer API.
- Database:** only SHA-256 fingerprints of codes, cookies and links; Anthropic keys encrypted with AES-GCM.
- Retention:** readings older than 365 days deleted every night; acceptances in an append-only register.
- Personal data:** no name, no email (of the Google account only an HMAC-SHA256 fingerprint; the email stays on the phone); photos and files processed and discarded; data in the EU.

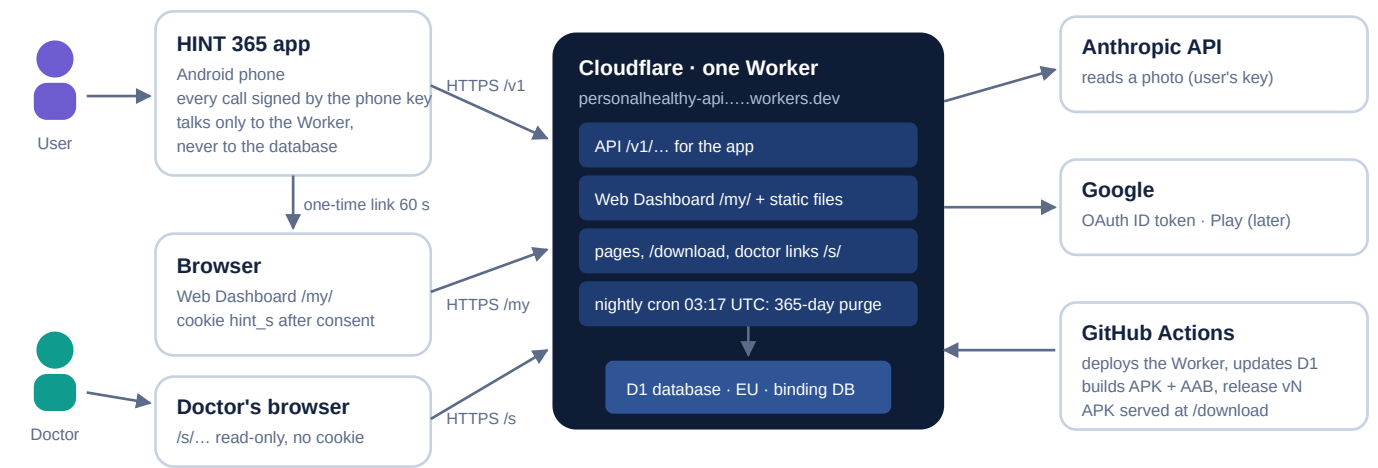
Releasing a version

- Change on a branch → pull request → merge into main .
- GitHub Actions updates D1, deploys the Worker, builds the APK and the AAB, creates release v0.1.N and puts the APK at /download .
- The site changes at once; the app updates by installing the new APK.

Runtime flow and delivery

Where each part runs today, who talks to whom, and how a change goes from the chat to the phone.

Runtime flow everything runs on Cloudflare; only the Worker touches the database



Who reads and writes what

- **App → Worker → D1**: every reading (voice, photo, by hand), the account, the key, the acceptances. The app never opens the database; it calls `/v1/...`, signed by the phone key.
- **Browser → Worker → D1**: the Web Dashboard reads the readings through `/my/api/...` with the cookie; the owner's Admin tab reads usage numbers only.
- **Doctor → Worker → D1**: a read-only period through `/s/...`, until it expires or is withdrawn.
- **Not used**: Vercel. One provider only (Cloudflare) keeps the database next to the code that uses it, in the EU, on the free plan.

Four flows, step by step

1. **Voice reading**: app → `POST /v1/bp/voice` → Worker checks signature and values → D1.
2. **Photo (AI)**: app → `POST /v1/bp/scan` → Worker → Anthropic with the user's key → values back to the phone → user confirms → `/v1/bp/confirm` → D1. The photo is not kept.
3. **Web Dashboard**: app → `/v1/web/code` → browser opens `/my/#c=...` → cookie notice → `/my/session` → cookie → `/my/api/data`.
4. **Doctor**: dashboard → `/my/api/share` → link `/s/...` sent by WhatsApp or email.

Roles

Who	Does
Angelo · architect	Decides design, rules and priorities in the chat; tries each APK; says what goes and what does not.
Claude · developer	Writes the change, tests it, merges it, watches the pipeline, sends the APK in the chat.

CI/CD, from the chat to the phone

1. **Change** on branch `claude/...`, with docs and rules updated in the same commit.
2. **Test before merging**: Worker bundle (`wrangler deploy --dry-run`), page checks in Chromium at phone and desktop width, JavaScript and string files checked, documents rendered and looked at.
3. **Pull request** → **squash merge** into `main`.
4. **GitHub Actions** `build.yml`, on every push to `main`:
 - ① `server`: D1 tables and new columns, Worker deployed, secrets set;
 - ② `apk`: Gradle compiles (this is the Kotlin test), release `v0.1.N` with APK and AAB;
 - ③ `publish`: Worker deployed again with the new APK at `/download`.
5. **Check after deploy**: release present, APK checksum matches, D1 checked when data changed; APK sent in the chat.
6. **Rollback**: revert the pull request; the pipeline redeploys the previous state. Old apps can be blocked from the Admin tab.

Not yet automated: unit tests and tests on a real phone. The APK is tried by the architect.